

WEB VAPT EVIDENCE FILE DOCUMENTATION

19-csrf-forged-request-proof.png

Field	Details
Project	Enterprise Security Assessment Lab
Module	Sub-Project 1 - Web Application VAPT
Evidence Row	26 - CSRF
Evidence File	19-csrf-forged-request-proof.png
Result Type	Forged request proof
Prepared For	GitHub portfolio documentation

Document Purpose

This PDF documents one specific evidence file from the Web VAPT evidence table. It embeds the actual screenshot, explains what the screenshot proves, maps it to the methodology, and records professional interpretation, risk, remediation, and redaction guidance for GitHub publication.

1. Embedded Evidence Screenshot

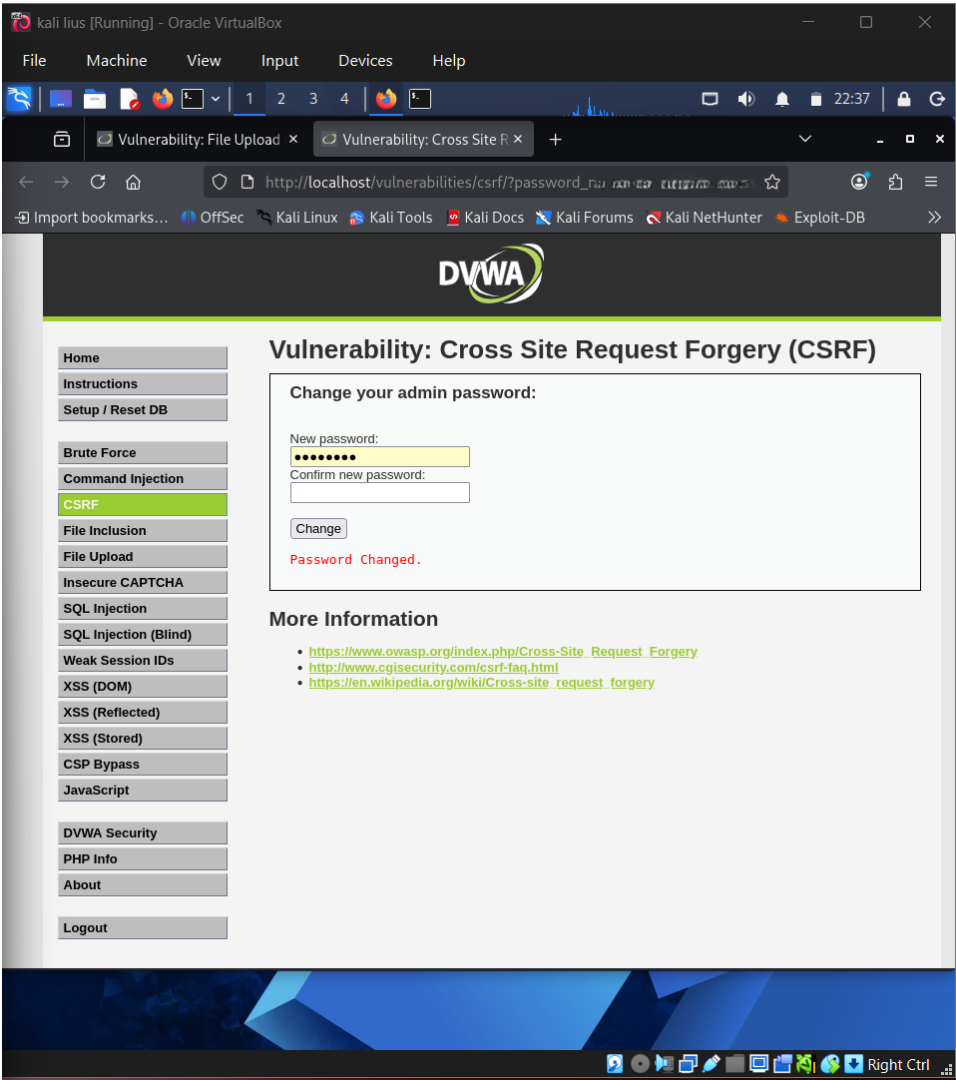


Figure 1 - Actual screenshot evidence: 19-csrf-forged-request-proof.png

What this screenshot proves

The screenshot shows the DVWA CSRF page accepting a request and displaying Password Changed.

2. Evidence Context

Area	Value
Testing Phase	Cross-Site Request Forgery Validation
Tool / Component	Browser / DVWA
Objective	Validate that a state-changing request could be forged without strong anti-CSRF protection.
Result Type	Forged request proof

3. Command / Workflow Used

Submit forged request to DVWA CSRF endpoint
Observe state-changing result such as Password Changed

The commands or workflow above represent the evidence-producing action. Placeholders such as , , or should be used in public documentation instead of live secrets or private infrastructure details.

4. Professional Interpretation

The screenshot shows the DVWA CSRF page accepting a request and displaying Password Changed.

This evidence should be treated as a supporting artifact, not as a standalone finding by itself. In a professional report, the screenshot supports a specific testing phase, validates an observation, and strengthens reproducibility when paired with methodology and remediation guidance.

5. Security Risk / Why It Matters

CSRF can force authenticated users to perform unwanted actions such as changing settings or credentials.

For this portfolio project, the risk is described in a real-world context while clearly noting that the target was an authorized DVWA/local lab environment. This avoids exaggerating lab results as production impact.

6. Recommended Remediation / Defensive Control

Use anti-CSRF tokens, SameSite cookies, Origin/Referer validation, and re-authentication for sensitive actions.

7. GitHub Redaction Requirements

Password values, URL query parameters, cookies, and session identifiers.

Before pushing to GitHub, confirm that screenshots do not expose cookies, session IDs, credentials, hashes, cracked passwords, private IPs, internal file paths, or any secret values. If the screenshot already contains sensitive information, blur or crop it before upload.

8. GitHub README Link Snippet

```
[Open Evidence PDF](./reports/evidence-file-documentation-with-screenshots/26_19-csrf-forged-request-proof_evidence_documentation.pdf)
```

Legal and Ethical Note

This evidence documents authorized testing against an intentionally vulnerable local lab target. The techniques described must not be used against public or third-party systems without explicit permission.